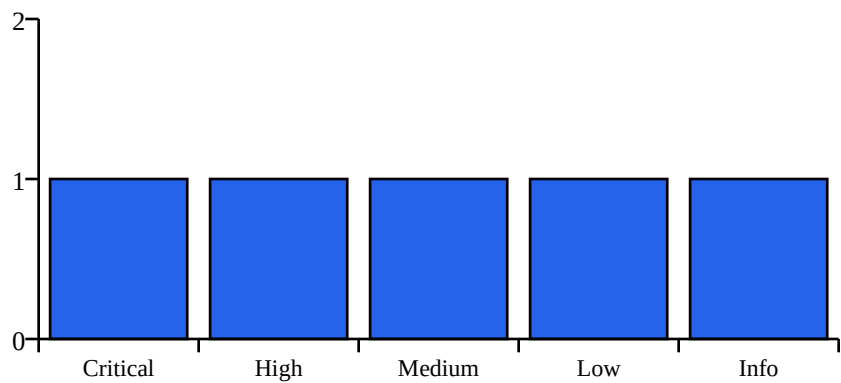


Security Assessment Report

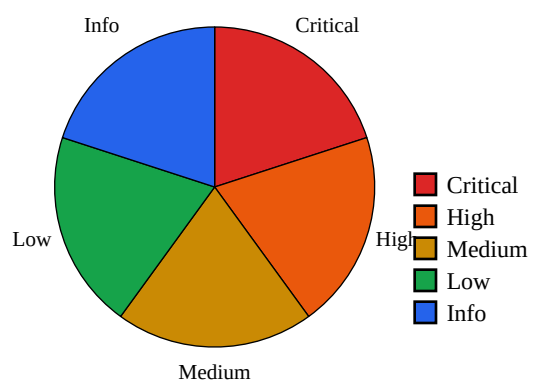
Generated: 2026-09-05 05:39 | Format: Detailed



Executive Summary

This report contains **5** security findings. Critical: **1**, High: **1**, Medium: **1**, Low: **1**, Info: **1**.

Overall Risk Rating: **HIGH**



Findings Summary

#	Title	Severity
1	SQL Injection in Login Form	CRITICAL
2	Cross-Site Scripting (XSS) in Comments	HIGH
3	Weak Password Policy	MEDIUM
4	Missing Security Headers	LOW
5	Server Version Disclosure	INFO

Detailed Findings

1. SQL Injection in Login Form [CRITICAL]

Description: The login form is vulnerable to SQL injection attacks, allowing unauthorized database access.

Evidence: Payload ' OR 1=1-- bypassed authentication on /login endpoint.

Remediation: Use parameterized queries and input validation. Implement prepared statements.

CVSS Score: 9.8

Affected: /api/login, /api/auth

2. Cross-Site Scripting (XSS) in Comments [HIGH]

Description: Stored XSS vulnerability in the comments section allows injection of malicious scripts.

Evidence: Injected alert('XSS') was stored and executed.

Remediation: Sanitize user input and implement Content Security Policy headers.

CVSS Score: 7.5

Affected: /comments

3. Weak Password Policy [MEDIUM]

Description: The application does not enforce minimum password complexity requirements.

Evidence: Passwords like '123' and 'password' were accepted.

Remediation: Enforce minimum 12-character passwords with complexity requirements.

Affected: /api/register

4. Missing Security Headers [LOW]

Description: Several security headers are missing from HTTP responses.

Evidence: X-Frame-Options, X-Content-Type-Options, and Strict-Transport-Security headers absent.

Remediation: Add recommended security headers to all responses.

Affected: All endpoints

5. Server Version Disclosure [INFO]

Description: The server reveals its version information in HTTP headers.

Evidence: Server header reveals: nginx/1.24.0

Remediation: Configure server to suppress version disclosure.

Affected: All endpoints

Timeline: 5 findings

